

CISM Domain 4

Incident Management, Recovery Strategies, Recovery Sites and BCP/DR Testing

Consolidated study notes from the supplied training screenshots and visible annotations

Domain mapping: These topics are primarily associated with CISM Domain 4, Information Security Incident Management. They also overlap with business continuity and disaster recovery planning concepts.

1. Evaluating Recovery Strategies

Before selecting a recovery strategy, the organization must evaluate business requirements, risk, available capabilities, recovery objectives and cost. The goal is to choose a strategy that supports management objectives without creating unreasonable expense or operational risk.

Factors to consider

- **Enterprise size, complexity and current state of recovery planning:** A small organization may need a simple recovery arrangement, while a large enterprise may need multiple sites, specialized capabilities and coordinated recovery across regions.
- **Alternative strategies:** Identify and compare options such as hot sites, warm sites, cold sites, mobile sites, reciprocal arrangements, duplicate sites, mirror sites and outsourced recovery services.
- **Trade-offs among scope, capabilities, risk and cost:** Faster recovery and stronger capabilities usually require greater investment. A low-cost option may have longer recovery times or limited capacity.
- **Outsourcing capabilities and comparison cost:** Compare external recovery services with internally managed capabilities, including service commitments, expertise, reliability, security and total cost.
- **Business interruption insurance:** Consider insurance to reduce the financial impact of disruption. Insurance does not replace the need for recovery capability.

The selected recovery strategy should

- Meet management objectives.
- Provide a basis for developing detailed incident management and response plans.
- Address probable events with acceptable recovery times at a reasonable cost.
- Consider the cost of preparing for possible disruptions and activating recovery capabilities.

Exam point: Select the recovery strategy based on business requirements, risk and cost-benefit analysis, not simply on the cheapest option or the most advanced technology.

2. Parameters for Selecting a Recovery Site

- **Probability of a major outage occurring:** Consider the likelihood of natural disasters, power failures, cyberattacks, infrastructure failures and other disruptive events.
- **Nature and extent of impact on the enterprise:** Determine how severely the disruption would affect the organization's ability to continue operations.
- **BIA operational requirements:** Use the Business Impact Analysis to understand critical processes, dependencies, required recovery capabilities and recovery objectives.
- **Management risk appetite:** Understand how much disruption and residual risk management is willing to accept.
- **Cost and benefit:** Compare the cost of establishing and maintaining the recovery site with the expected business benefit and risk reduction.

BIA connection: The BIA identifies business impacts and recovery requirements. Those requirements guide recovery-site selection.

3. Recovery Site Types

Site	Meaning and readiness	Data / hardware / people	Typical use
Hot site	A fully equipped recovery facility designed for rapid recovery.	Systems, hardware, connectivity and infrastructure are ready. Data may be replicated or restored depending on design. Trained personnel or support must be available.	Critical systems requiring short recovery times.

Site	Meaning and readiness	Data / hardware / people	Typical use
Warm site	A partially equipped recovery facility requiring additional configuration, software installation or data restoration.	Some hardware and infrastructure are available. Data may be replicated periodically or restored from backups. Technical staff are needed for activation.	A balance between recovery speed and cost.
Cold site	A facility with basic infrastructure but little or no ready-to-use IT equipment.	Hardware, software and data must be brought in or restored. Staff and vendors must prepare the environment.	Less time-sensitive systems where lower cost is important.
Mobile site	A portable recovery facility, often deployed in a trailer or transportable unit.	Portable equipment is supplied according to the design. Data must be supplied or restored. Deployment and technical personnel are required.	Recovery at different or temporary locations.
Duplicate site	A separate facility that duplicates the operational environment.	May contain duplicate infrastructure, systems and capacity. Data synchronization depends on the design.	High availability or recovery where duplicate capability is justified.
Mirror site	A replica of the primary environment, normally emphasizing continuous or near-continuous synchronization.	Data is continuously or near-continuously replicated. Systems are configured for rapid failover. Staff and operational procedures remain necessary.	Very rapid failover for critical services.
DRaaS	Disaster Recovery as a Service, where an external provider supplies and manages some or all recovery capabilities.	The provider supplies infrastructure and recovery services. Data protection, staffing, recovery times and security depend on the contract and design.	Organizations needing external expertise or cloud-based recovery.
Reciprocal site	Two organizations agree to support each other's recovery needs.	Capacity, compatibility, security, priorities and contractual terms must be defined. The arrangement may not be sufficient during simultaneous disasters.	Organizations seeking a shared or potentially lower-cost arrangement.

Correction / exam trap: A hot site is not automatically the same as a mirror site. A hot site can be ready for rapid recovery without continuously synchronized data. A mirror site specifically emphasizes replication and synchronization.

4. Effective Incident Management

Incident management aims to detect, record, manage and resolve security incidents in a controlled manner while minimizing business disruption.

What effective incident management ensures

- **Rapid detection of security events:** Identify suspicious activity and security events promptly.
- **Proper recording of all incidents:** Maintain incident records, timelines, actions, decisions and outcomes.
- **Efficient management of response:** Coordinate people, processes, technology and decisions according to approved procedures.
- **Limited impact to operations:** Contain incidents and minimize disruption while preserving necessary security controls.

Incident documentation requirements

- **Complete incident details:** What happened, when, affected systems, severity, scope and relevant evidence.
- **Response activity tracking:** Actions taken, responsible persons, decisions, timestamps and results.
- **Planning information collection:** Information needed to plan and coordinate the response.
- **Forensic data preservation:** Preserve relevant evidence reliably for investigation, legal, regulatory or disciplinary purposes.

5. IS Manager's Role in Incident Response

- **Maintain incident response readiness:** Ensure current procedures, trained personnel, tools, communication channels and response capabilities.
- **Contain and minimize the effect of the incident:** Coordinate containment and response actions to reduce damage and disruption.
- **Notify appropriate stakeholders:** Escalate according to severity, impact and approved communication requirements.
- **Recover quickly and efficiently:** Coordinate restoration of affected services within approved recovery objectives.
- **Balance operational and security processes:** Avoid unnecessary business disruption without weakening security.
- **Handle legal and law-enforcement-related issues:** Coordinate with legal, compliance, privacy and law-enforcement stakeholders when required; preserve evidence and follow applicable procedures.

24x7 annotation: The visible handwritten note near the IRT section emphasizes response coverage appropriate to organizational risk and operational requirements. A global organization with critical services may need 24x7 coverage, which can be provided through internal teams, on-call arrangements or managed services.

6. Incident Response Team (IRT) Models

Model	Description	Suitable context
Central IRT	One team handles incidents across the organization.	Smaller or centralized organizations.
Distributed IRT	Multiple teams handle incidents for different business segments, regions or organizational units.	Large or geographically distributed organizations.
Coordinating IRT	A central function provides guidance, coordination and standardized approaches to distributed teams.	Large enterprises needing local response plus central governance.
Outsourced IRT	An external provider handles some or all incident response functions.	Organizations lacking internal expertise, tools or sufficient coverage.

Selection factors: Organization size, geographical distribution, incident volume and complexity, response-time requirements, internal expertise, cost, outsourcing needs and the need for centralized standardization.

7. Recovery Plan Updates

Recovery plans must evolve as the organization changes. A plan that was correct when created may become inaccurate when applications, systems, business processes, suppliers or physical environments change.

Factors that affect recovery plan requirements

- **Inadequate strategy or misalignment with enterprise needs:** The current recovery strategy no longer supports business requirements.
- **New applications developed or acquired:** New applications introduce new data, infrastructure, dependencies and recovery requirements.
- **Changes in business strategy altering the significance of critical applications:** A previously less important application may become business-critical.
- **Changes in the environment that render present provisions inappropriate:** Changes in technology, threats, suppliers, regulations or infrastructure may make current provisions inadequate.
- **Changing physical and environmental circumstances:** Changes in buildings, locations, power, climate-related exposure or other physical conditions may affect recovery.

What the IS Manager must do

- Establish a process to update recovery plans as changes occur within the enterprise.

- Assess response and recovery requirements during the change-management process.
- Review and update plans and strategies according to a defined schedule.

8. Maintaining Recovery and Continuity Plans

Business processes and technology undergo almost continuous change. A BCP/DR plan that is developed and tested may become outdated within months and potentially obsolete within a year.

Maintenance strategies

- Establish a schedule for reviewing principal disaster recovery documents.
- Include DR document review in every business process or system change.
- Make document updates a required step in the SDLC.
- Conduct periodic testing to validate document accuracy.

Example: If an organization moves from an on-premises authentication platform to a cloud identity provider, the recovery plan must be reviewed for connectivity, backup administrator access, dependencies, recovery procedures and testing requirements.

Key distinction: Updating the plan is not enough. Testing must confirm that the updated procedures actually work.

9. Testing BCP and DR Plans

Testing validates whether recovery procedures, resources, communication mechanisms and teams can achieve the required recovery objectives.

Why testing is important

- Promotes collaboration and coordination among teams.
- Provides a useful training tool.
- Identifies gaps, incorrect assumptions and missing dependencies.
- Consumes valuable time and resources, so it must be planned carefully.
- Validates whether recovery objectives are achievable in practice.

Testing principles

- Define the relationship between teams clearly.
- Understand and integrate with the scope and capabilities of existing teams.
- Plan and control tests carefully to avoid placing the business at increased risk.
- Develop methodical test objectives that produce measurable benefits.
- Maintain a testing schedule for all critical functions.
- Consider testing after major plan drafts or significant changes.

10. Progressive Testing Levels

Level	Test type	What happens / purpose
1	Checklist review	Paper-based verification of recovery procedures, contact lists and resource requirements. Confirms that documents are current.
2	Structured walkthrough	The team reviews recovery steps on paper. A facilitator guides each stage and participants discuss actions and dependencies.
3	Simulation / tabletop	Participants role-play a disaster scenario. A facilitator introduces evolving events and participants respond as the scenario unfolds.

Level	Test type	What happens / purpose
4	Parallel test	The recovery site is activated while the primary business continues. Recovery processing validates capacity, procedures and data integrity without shutting down the primary operation.
5	Full interruption / cutover	The primary operation is shut down and operations shift to the recovery site. This is the most realistic and rigorous listed test, but it has the highest business risk.

11. What Testing Should Validate

Recovery element	What the test should confirm
RTO	The required recovery time is achievable.
RPO	The acceptable data-loss objective is achievable.
MTD	The business can recover within its maximum tolerable downtime.
SDO	The required service delivery objective can be achieved.
Offsite backups	Backups can be retrieved and restored.
Alternate site	Capacity and security controls are adequate.
Communication	Communication trees and escalation triggers work.
Vendors	Third-party response commitments are realistic.

Testing discipline: Test progressively, at least annually and after major system or business changes as appropriate; document results, gaps and remediation owners; include IT, business owners, HR, PR, legal and vendors where relevant; and update BCP/DR plans after each test.

12. High-Value Exam Distinctions

- **Recovery strategy vs. recovery plan:** The strategy defines the overall recovery approach and capabilities. The plan defines detailed procedures, responsibilities and execution steps.
- **BIA vs. recovery-site selection:** The BIA identifies business impact and recovery requirements. Site selection uses those requirements together with risk, cost and management objectives.
- **Parallel test vs. full interruption:** In a parallel test, the primary operation continues. In a full interruption test, the primary operation stops and the recovery site takes over.
- **Most rigorous vs. most appropriate:** Full interruption/cutover is the most rigorous listed test, but the appropriate test depends on risk tolerance and business requirements.
- **Incident management vs. disaster recovery:** Incident management focuses on detecting, responding to, containing and managing incidents. Disaster recovery focuses on restoring services and operations after disruption. They must work together.
- **Documentation vs. forensic preservation:** Documentation supports coordination and accountability. Forensic preservation focuses on maintaining evidence integrity for investigation or legal use.

13. One-Page Memory Map

BIA → Recovery requirements → Strategy selection → Recovery plan → Testing → Maintenance

When the organization changes, reassess recovery requirements, update the plan and test again.

Final revision checklist

- Recovery strategy selection is based on business needs, risk, recovery objectives and cost-benefit analysis.
- BIA operational requirements are a major input into recovery-site selection.

- Hot, warm and cold sites differ mainly in readiness, recovery speed and cost.
- The IS Manager maintains readiness, coordinates response, manages stakeholders, supports recovery and handles legal requirements.
- Central, distributed, coordinating and outsourced IRT models differ in how responsibility is organized.
- Recovery plans must be updated when business, technology, applications or the environment changes.
- Testing must be progressive, controlled, documented and followed by remediation and plan updates.
- Full interruption/cutover is the most rigorous listed test, but not automatically the best test for every organization.

Note on annotations: The visible handwritten annotations were incorporated where legible, including the 24×7 response-coverage note, the emphasis on primary-to-secondary recovery, and the marked points concerning incident response, plan updates and testing. Unclear handwritten text was not guessed.